SOP-IAM-04: Run Access Review (Quarterly)

Managers confirm who still needs which access; anything not justified is removed

Project	**AccessGuard Health** — Horizon Valley Medical Center (HVMC) Healthcare IAM
SOP ID	SOP-IAM-04
Version / effective	1.0 / 9 November 2026
Owner	IAM Administrator (Sabitha S Karanavar)
Approved by	IT Security (Security Supervisor)
Review	Every 12 months, or after any incident or tooling change
Performed by	IAM Administrator prepares and applies; managers and the Security Supervisor decide
Tool	`build_review_pack.py` (Excel review pack) · `apply_decisions.py`

1. Schedule and scope

- Every quarter (campaign name HVMC-AR-YYYY-Qn); next: HVMC-AR-2027-Q1, January 2027
- In scope: every SG-* group membership, every direct application assignment, directory roles (Global Administrator), Azure role assignments, and disabled accounts that still hold any access

2. Reviewers

- Each user's **manager** reviews their staff
- Department leads, test and admin accounts: IAM Administrator; privileged roles: Security Supervisor
- Nobody reviews their own access

3. Procedure

1. Take a read-only snapshot of the tenant and build the pack: `python3 build_review_pack.py`
2. Each line shows the access, a rule-based flag (green / amber / red) and a recommendation
3. Send the pack to reviewers with a due date (10 working days); unanswered lines are escalated to the Security Supervisor
4. Reviewers record **Keep** or **Remove** on every line, with a short justification
5. Dry run: `python3 apply_decisions.py` ; check every Remove action
6. Apply: `python3 apply_decisions.py --apply` ; re-run the application sync and the RBAC coverage check
7. Write findings for the next campaign (preparation notes)

4. Verify and evidence

- Every removed access is gone (re-read from Entra ID / Azure); coverage check shows no extra access
- Keep: decided review pack (Excel), actions log (JSON), reviewer sign-off, findings and preparation notes

5. Never

✗ Approve everything without reading it (“rubber-stamping”); a Keep needs a reason
✗ Let a reviewer decide on their own access
✗ Remove access without the dry run, or change decisions after sign-off without a new approval
✗ Skip disabled accounts: they are where forgotten access hides

Example run: HVMC-AR-2026-Q4 (20 Oct 2026): 94 lines, 93 Keep, 1 Remove (a disabled test account's Azure data role); legacy EHR app brought under group management · System: Microsoft Entra ID (HVMC tenant, Free tier, security defaults on). Every change runs as a dry run first; nothing is changed without -Apply / --apply.